Just like we've discussed for Cedar, to evaluate this XACML policy, the PEP would send a request to the PDP, including attributes about the requester (subject), the document (resource), the action, and any relevant environment conditions (such as time or location).

NOTE

The preceding policies *do not* address what happens when a document is not confidential. That would be handled by a different policy or rule that allows access to documents that are not confidential. For the rest of this chapter, we will ignore cases where the document is not confidential and focus only on policies for confidential documents.

8.1.2 Applying the PARC model to XACML

Let's look at how XACML fits into the PARC model introduced in Chapter 7:

- **Principal**—XACML refers to the principal as the "subject" and represents them using attributes like username, department, and clearance. These attributes are supplied in the access request and can be used in policy conditions. XACML doesn't have a first-class object model for principals; they're represented only by their attributes.
- **Action**—XACML represents actions (such as read, write, or delete) as string-valued attributes in the request, typically `action:id`. Policies match actions either in the `<Target/>` element or within the `<Condition/>` of a rule. XACML does not specify an action type system, so consistency is left to the policy author.
- **Resource**—XACML describes resources entirely through attributes such as `resource:id`, `resource:type`, or `resource:owner-department`. There is no native support for object hierarchies or relationships between resources; everything is flattened into the attribute model. This complicates the expression of fine-grained or graph-based access control.